SENTINEL APPSEC | APPLICATION SECURITY VERIFICATION

http://youtube.com/

Report ID: sentinel-audit-1794155885968 | Duration: 3709 ms

Date: Sun, 08 Nov 2026 16:38:05 GMT | URL: http://youtube.com/

CRITICAL	HIGH	MEDIUM	LOW	PASSED
0	0	2	0	16

1. Executive Verification Summary

The Sentinel AppSec engine verified 2 security finding(s) backed by empirical HTTP header responses, SPA-filtered sensitive route probes, live OSV.dev CVE advisories, or exact source code line matches, alongside 16 passed security control(s).

2. Empirical Vulnerability Ledger (2)

01. [MEDIUM] Permissive Content-Security-Policy Allows Unsafe Script Execution

CWE-693 | A05:2021 Security Misconfiguration | Target: http://youtube.com/

Summary: The Content-Security-Policy header is present but contains 'unsafe-inline' or 'unsafe-eval' without cryptographic nonces or hashes.

Impact: Attackers can bypass CSP protections to run injected inline scripts or eval()-based payloads.

```
content-security-policy: require-trusted-types-for 'script', base-uri 'self';object-src
'none';script-src 'report-sample' 'nonce-R2yZ8df91y4O0UKOjsd0Ow' 'unsafe-inline' 'strict-dynamic'
https: http: 'unsafe-eval';report-uri https://csp.withgoogle.com/csp/youtube_main/strict
```

Remediation: Remove 'unsafe-eval' and 'unsafe-inline' from script-src or pair inline scripts with per-request cryptographic nonces.

02. [MEDIUM] External Third-Party Script Loaded Without Subresource Integrity (SRI)

CWE-829 | A08:2021 Software and Data Integrity Failures | Target: http://youtube.com/

Summary: Found 9 external <script> tag(s) loaded from third-party origins without a cryptographic integrity="sha384-..." attribute.

Impact: If the external CDN or third-party host is compromised, malicious JavaScript will execute inside your application with full DOM access.

```
<script src="https://www.youtube.com/s/desktop/4e57be2c/jsbin/web-
animations-next-lite.min.vflset/web-animations-next-lite.m in.js" nonce="R2yZ8df91y4O0UKOjsd0Ow">
<script src="https://www.youtube.com/s/desktop/4e57be2c/jsbin/webc
omponents-all-noPatch.vflset/webcomponents-all-noPatch.js" nonce="R2yZ8df91y4O0UKOjsd0Ow">
<script src="https://www.youtube.com/s/desktop/4e57be2c/jsbin/fetc
h-polyfill.vflset/fetch-polyfill.js" nonce="R2yZ8df91y4O0UKOjsd0Ow">
<script src="https://www.youtube.com/s/desktop/4e57be2c/jsbin/inte
rsection-observer.min.vflset/intersection-observer.min.js" nonce="R2yZ8df91y4O0UKOjsd0Ow">
```

Remediation: Add integrity="sha384-..." and crossorigin="anonymous" attributes to all third-party CDN scripts.

3. Verified Passed Security Controls (16)

[PASS] **Encrypted Transport / HTTPS Context Verified (http://youtube.com/)**
`Transport verified on http://youtube.com/ (HTTP 200)`

[PASS] **HTTP Strict-Transport-Security (HSTS) Active (http://youtube.com/)**
`strict-transport-security: max-age=31536000`

[PASS] **Anti-Clickjacking Frame Restriction Verified (http://youtube.com/)**
`x-frame-options: SAMEORIGIN`

[PASS] **MIME-Sniffing Protection (nosniff) Enforced (http://youtube.com/)**
`x-content-type-options: nosniff`

[PASS] **Cross-Origin Resource Sharing (CORS) Origin Isolation Verified (http://youtube.com/)**
`Untrusted origin (https://untrusted-origin.sentinel.audit) was not reflected (no ACAO header)`

[PASS] **Framework Fingerprinting Headers (X-Powered-By) Suppressed (http://youtube.com/)**
`x-powered-by header absent and server version masked`

[PASS] **Cookie Security Attributes (HttpOnly, Secure, SameSite) Verified (http://youtube.com/)**
`set-cookie: VISITOR_PRIVACY_METADATA=CgJKUBIEGgAgJg%3D%3D; Domain=.youtube.com; Expires=Fri, 07-May-2027 16:38:02 GMT; Path=/; Secure; HttpOnly; SameSite=none`

[PASS] **Sensitive Route Protected (/.env) (http://youtube.com/.env)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **Sensitive Route Protected (/.git/config) (http://youtube.com/.git/config)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **Sensitive Route Protected (/https://www.youtube.com/s/desktop/4e57be2c/jsbin/web-animations-next-lite.min.vflset/web-animations-next-lite.min. js.map) (http://youtube.com/https://www.youtube.com/s/desktop/4e57be2c/jsbin/web-animations-next-lite.min.vflset/web-animati ons-next-lite.min. s.map)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **Sensitive Route Protected (/https://www.youtube.com/s/desktop/4e57be2c/jsbin/webcomponents-all-noPatch.vflset/webcomponents-all-noPatch.js.map) (http://youtube.com/https://www.youtube.com/s/desktop/4e57be2c/jsbin/webcomponents-all-noPatch.vflset/webcomponents- all-noPatch.j s.map)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **Sensitive Route Protected (/https://www.youtube.com/s/desktop/4e57be2c/jsbin/fetch-polyfill.vflset/fetch-polyfill.js.map) (http://youtube.com/https://www.youtube.com/s/desktop/4e57be2c/jsbin/fetch-polyfill.vflset/fetch-polyfill.js.map)**
`Returned HTTP 404 (text/html; charset=utf-8)`

[PASS] **Client JavaScript Bundles Verified Free of Leaked Secrets (http://youtube.com/)**
`Inspected 5 bundle(s) (193398 bytes); 0 leaked keys found`

[PASS] **HTTP Verb & TRACE Restriction Verified (http://youtube.com/)**
`OPTIONS check completed; TRACE disabled`

[PASS] **GraphQL Unauthenticated Introspection Protected (http://youtube.com/)**
`Probed /graphql and /api/graphql - no unauthenticated schema dump exposed`

[PASS] **URL Redirect Query Parameters Validated Against Open Redirects (http://youtube.com/)**
`Tested ?redirect=, ?next=, ?url=, ?returnTo= - no external 3xx Location reflection`